BİLGİ SİSTEMLERİ DENETİM RAPORU

Denetlenen Kurum: FinCore Bank

Denetim Tarihi: 08.07.2026

Denetçi: Necdet Emre Bayraktar (Bilgi Sistemleri Denetçisi Adayı)

Sistem: AWS Amazon Linux 2023

1. Yönetici Özeti

FinCore bünyesinde barındırılan ve sistem verilerini işleyen AWS bulut tabanlı sunucu altyapısında gerçekleştirilen güvenlik denetimi sonucunda, sistemin genel güvenlik duruşunun kritik seviyede zayıf olduğu tespit edilmiştir. Sistem sahiplerinin "güvenlik yapılandırmalarının eksiksiz olduğu ve gereksiz kullanıcı/veri barındırılmadığı" beyanlarına karşın, sahada yapılan teknik testler bu iddiaları çürütmüştür.Yapılan denetim sonrası personelin yeterli özveriyi göstermediği ve düzenli kontrollerin yapılmadığı anlaşılmıştır.

İşletim sistemi 2029 yılına kadar (SUPPORT_END="2029-06-30") destek alıyor olmasına rağmen, sistem bakım süreçleri terk edilmiştir. "Derinlemesine Savunma" (Defense in Depth) prensibinin uygulanmadığı(sadece dış güvenlik unsurlarına güvenme), veri gizliliğinin ve bütünlüğünün (CIA Üçlüsü) ihlal edildiği, kimlik yönetimi süreçlerinde devasa boşluklar bulunduğu saptanmıştır. Olası bir siber saldırıda kurumun tüm bulut altyapısının ele geçirilmesi ve ağır KVKK ihlalleri yaşanması an meselesidir.

2. Denetim Kapsamı

Bu denetim; FinCore'a ait ip-172-31-21-74 IP adresli sunucunun aşağıdaki bileşenlerini kapsamaktadır:

- Kullanıcı ve Kimlik Yönetimi (IAM)
- Parola ve Oturum Politikaları
- Ağ Güvenliği ve Açık Portlar
- Servis ve Hardening (Sıkılaştırma) Yapılandırmaları
- İşletim Sistemi Yama (Patch) Yönetimi
- Dosya/Dizin İzinleri ve Hassas Veri Güvenliği
- Loglama ve İzleme Mekanizmaları

3. Yapılan Testler

Denetim sürecinde sistem üzerinde doğrudan teknik doğrulama ve konfigürasyon analizleri gerçekleştirilmiştir:

- Kullanıcı aktiviteleri ve oturum süreleri için uptime, last, lastlog ve w komutları ile analiz.
- Parola politikaları ve ayrıcalıklı yetkiler için chage ve sudo -l yapılandırma testleri.
- Ağ seviyesinde zafiyet tespiti için ss -tulpn ve güvenlik duvarı (firewalld) durum kontrolleri.
- Arka plan servislerinin güvenliği için systemctl analizleri ve SSH (sshd_config) konfigürasyon incelemesi.
- Yama yönetimi için dnf check-update ve çekirdek (rpm) güncellik kontrolleri.
- Veri ihlallerini tespit etmek amacıyla find -perm ile dosya izin ve sahiplik taramaları.

4. Tespit Edilen Bulgular

4.1. Kimlik Yönetimi ve Hesap Verilebilirlik

- **Zombi ve Atıl Hesaplar:** Kurum beyanının aksine, canlı ortamda test ve intern (stajyer) hesapları aktiftir. tempconsultant (geçici danışman) hesabının parolası en son 1 Ocak 2024'te değiştirilmiş ve lastlog kayıtlarına göre bu hesaplara hiç giriş yapılmamıştır. Bu hesaplar sistemde unutulmuş potansiyel arka kapılardır (backdoor).
- **Paylaşımlı Hesap Kullanımı:** ec2-user hesabına birbirinden farklı birçok IP adresinden giriş yapıldığı tespit edilmiştir. Bu durum hesap verebilirliği (accountability) ortadan kaldırmakta, "işlemi kimin yaptığını" ispatlamayı imkansız hale getirmektedir.
- **Belirsiz Yönetim Hesapları:** admin hesabının fiziksel olarak kime ait olduğu belirsizdir. backupsvc (yedekleme servisi) hesabına /bin/bash kabuğu atanmıştır; bu durum, servisin bir kullanıcı gibi sisteme interaktif giriş yapabilmesine (zaman aşımına uğramadan) olanak tanımaktadır.Ayrıca admin hesabının yönetiminin kimde olduğu belirlenmediği için yapılan işlemlerde sorumluluğun kimde olduğunu anlamaya engel olacaktır.

4.2. Parola ve Oturum Politikaları

- **Parola Süreci Eksikliği:** İncelenen tüm hesaplarda parola geçerlilik süresi "hiçbir zaman" (Password expires: never) ve değiştirme aralığı 99999 gün olarak ayarlanmıştır. Standart bir parola politikası bulunmamaktadır.

- **Kritik Yetki Zafiyeti (Privilege Escalation):** test hesabına (ALL) NOPASSWD: ALL yetkisi tanımlanmıştır. Bu hesap parolasız olarak sistemde en üst düzey (root) yetkiye erişebilmektedir.

- **Oturum Zaman Aşımı (Session Timeout):** SSH konfigürasyonunda ClientAliveInterval ve ClientAliveCountMax değerleri yorum satırına (#) alınarak devre dışı bırakılmıştır. Sistemde 40 gündür asılı kalan ve açık unutulan 4 farklı aktif yönetici terminali (pts) tespit edilmiştir.

4.3. Sistem Hardening, Ağ ve Servis Güvenliği

- **Açık ve Şifresiz Servisler:** Sistemde FTP (vsftpd) sunucusu :::21 portundan tüm internete açık olarak dinleme yapmaktadır. Üstelik servis enabled olarak ayarlandığından, her yeniden başlatmada otomatik olarak çalışacaktır. Şifresiz veri ileten FTP kullanımı doğrudan veri sızıntısı ve *Man-in-the-Middle* saldırısı riskidir. (Port 80 yerine güvenli 443 tercih edilmemiştir).

- **Güvenlik Duvarı Yokluğu:** Sunucuda firewalld veya benzeri bir host-based güvenlik duvarı bulunmamaktadır. Sadece dış AWS güvenliğine güvenilmiş olup, "Derinlemesine Savunma" kuralı ihlal edilmiştir.

- **Loglama Zafiyeti:** Sistem olaylarını kaydeden temel güvenlik servisi auditd, başlangıçta disabled (kapalı) olarak ayarlanmıştır. Olası bir sunucu yeniden başlatılmasında sistemin izlenebilirliği tamamen körleşecektir.

4.4. Yama (Patch) Yönetimi

- **Güncelleme İhmali:** Sunucunun 40 gündür yeniden başlatılmadığı (uptime) ve 1 aydan uzun süredir yayınlanan Amazon Linux güncellemelerini almadığı görülmüştür. Bekleyen çekirdek (kernel) güncellemeleri, sunucu reboot edilmediği için devreye girmemiştir.

4.5. Hassas Veri İhlali ve CIA Üçlüsü

- **Dünyaya Açık (World-Writable) Dosyalar:** Sistemde root tarafından oluşturulmuş olan son derece kritik dosyaların, herkesin okuyup yazabileceği ve silebileceği 777 (-rwxrwxrwx) iznine sahip olduğu saptanmıştır:
    - /auditlab/customer_data.txt (Müşteri Verileri)
    - /finans/maaslar_2026.csv (Maaş Verileri)
    - /uygulama/veritabani.conf (Veritabanı Şifreleri)
    - /yedekler/aws_anahtarlari.txt (AWS Bulut Erişim Anahtarları)
    - /ik/personel_bilgileri.txt (KVKK Kapsamında Personel Verileri)
    - /backup/musteriler.sql (Veritabanı Yedeği)
    - /paylasim/yonetim_primleri.xlsx (Yönetim Kurulu Finansal Bilgileri)
-

- Bu zafiyet, yetkisiz bir kullanıcının veya stajyerin maaşları değiştirmesine, veritabanını silmesine veya KVKK ihlali yaratmasına olanak tanımaktadır. (Dosyalar 600 yetkisiyle korunmamıştır).

5. Risk Değerlendirmesi

Risk Kategorisi	Risk Seviyesi	Zafiyet Açıklaması ve Olası Etki
Bulut Altyapısı Ele Geçirilmesi	**Kritik**	AWS anahtarlarının açıkta (777) olması, saldırganın yalnızca sunucuyu değil, tüm kurum bulut mimarisini ele geçirmesine neden olur.
KVKK ve Veri İhlali	**Kritik**	Personel ve müşteri kimlik/iletişim bilgilerinin korunmasız bırakılması, yasal yaptırımlara ve itibar kaybına yol açacaktır (Bütünlük ve Gizlilik ihlali).
Yetki Yükseltme (Sistem İhlali)	**Kritik**	test hesabındaki NOPASSWD zafiyeti ve açık unutulan aktif oturumlar sayesinde sunucu tamamen ele geçirilebilir.
Ağ Güvenliği (Defense in Depth)	**Yüksek**	Firewall olmaması ve FTP (Port 21) üzerinden açık metin şifre/veri iletimi, ağ dinleme saldırılarına zemin hazırlamaktadır.
İzlenebilirlik (Accountability)	**Yüksek**	Paylaşımlı hesap (ec2-user) kullanımı ve auditd servisinin kapalı olması, bir saldırı anında failin bulunmasını ve delil toplanmasını imkansız kılar.

6. Öneriler ve İyileştirme Planı

Sistemdeki zafiyetlerin giderilmesi için aşağıdaki aksiyonların ivedilikle alınması tavsiye edilmektedir:

1. **Kimlik ve Erişim Yönetimi (IAM) Temizliği:** * tempconsultant, intern ve test hesapları derhal sistemden silinmelidir.
    - backupsvc hesabı interaktif girişleri engellemek için nologin kabuğuna (/sbin/nologin) geçirilmelidir.
    - test kullanıcısındaki NOPASSWD yetkisi sudoers dosyasından derhal kaldırılmalıdır.
2. **Parola ve Oturum Sıkılaştırması:** * Tüm kullanıcılara 90 günlük parola değiştirme zorunluluğu (password aging) getirilmelidir ve belirli standartlarda denetim yapılmalıdır.
    - Paylaşımlı (ec2-user) hesap kullanımı yasaklanmalı, tüm yöneticilere izlenebilir bireysel hesaplar açılmalıdır.
    - /etc/ssh/sshd_config dosyasında ClientAliveInterval ve ClientAliveCountMax ayarları aktif edilerek otomatik zaman aşımı devreye alınmalıdır.
3. **Ağ Güvenliği ve Servisler:** * Güvensiz FTP (vsftpd) servisi derhal kapatılmalı ve sistemden kaldırılmalıdır (Yerine SFTP kullanılmalıdır).
    - Web trafiği Port 80'den şifreli 443 (HTTPS) portuna yönlendirilmelidir.
    - Sunucu seviyesinde bir güvenlik duvarı kurularak yalnızca gerekli IP ve portlara izin verilmelidir.
4. **Veri Bütünlüğü ve Korunması:** * Tüm hassas dosyaların (aws_anahtarlari.txt, maaslar_2026.csv vb.) yetkileri derhal 600 veya 640 olarak güncellenmeli ve sahiplikleri yalnızca ilgili servis/yönetici ile sınırlandırılmalıdır.
5. **Yama ve Log Yönetimi:** * auditd loglama servisi systemctl enable auditd komutuyla başlangıçta çalışacak şekilde aktif edilmelidir.Bu haliyle yapılacak ilk reboot’da sistem audit logsuz olarak başlayacaktır.Öncelikle enable haline getirilip daha sonra reboot yapılmalıdır.
    - Sunucu planlı bir bakım penceresinde güncellenmeli (dnf upgrade) ve çekirdek yamalarının devreye girmesi için acilen yeniden başlatılmalıdır (Reboot).